

NEIGHBOR Write Up_Thembinkosi Zililo

“Check out our new cloud service, Authentication Anywhere -- log in from anywhere you would like! Users can enter their username and password for a totally secure login process! You definitely wouldn't be able to find any secrets that other people have in their profile, right?”

Access this challenge by deploying both the vulnerable machine by pressing the green "Start Lab Machine" button located within this task, and the TryHackMe AttackBox by pressing the "Start AttackBox" button located at the top-right of the page.

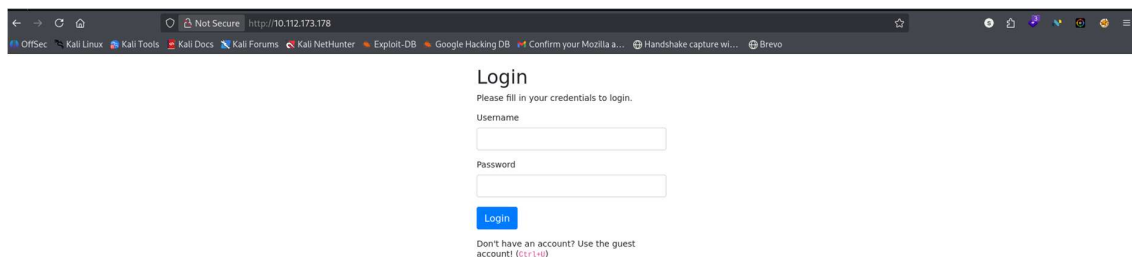
Navigate to the following URL using the AttackBox: <http://10.112.173.178>(opens in new tab)(opens in new tab)

Check out similar content on TryHackMe:

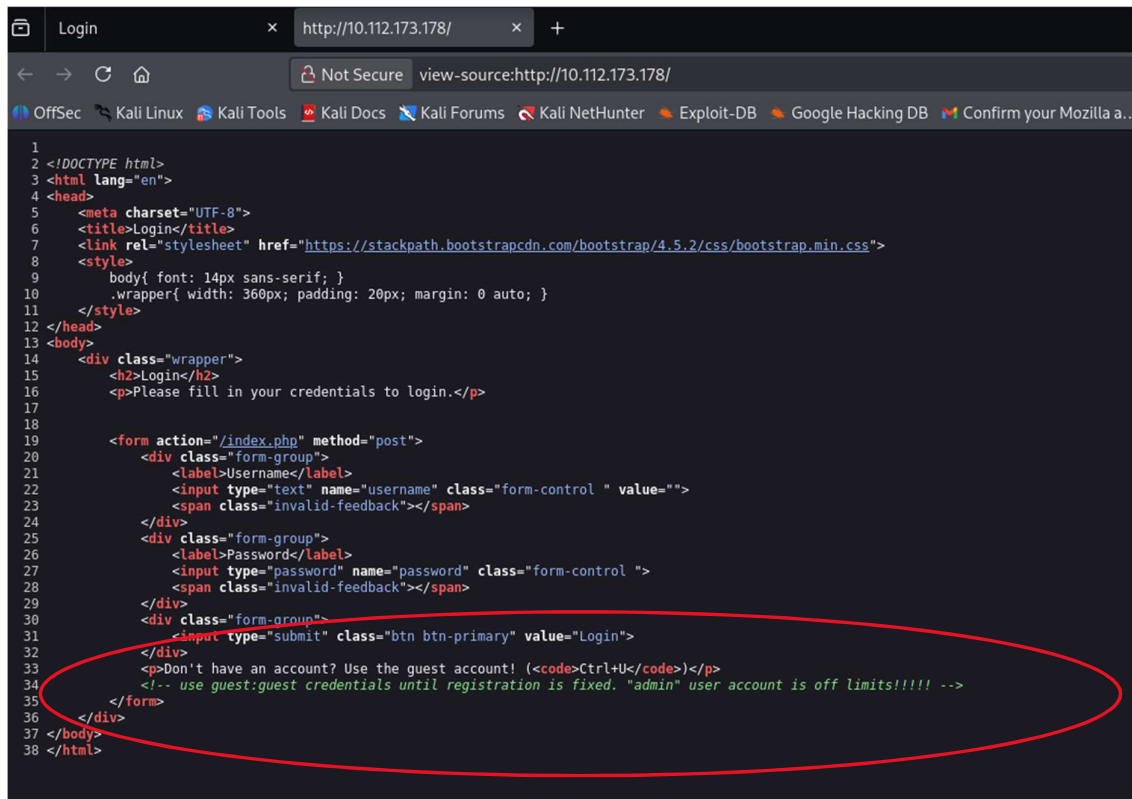
- [IDOR](#)

”

The information given was pretty straightforward, the login page means that our first suspect should be IDOR. And since it was already mentioned that we should check it out, I just skipped the usual “scan for open ports” opening and went straight to opening the site.

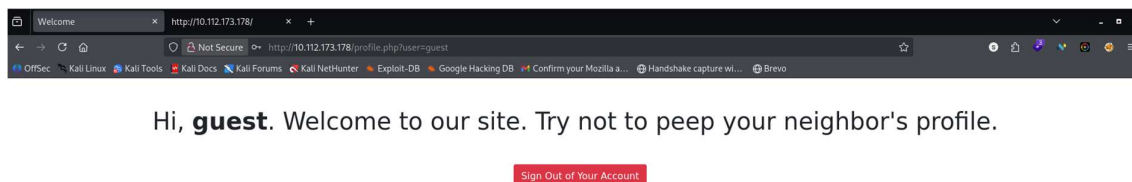


This site gives us a login page to fill in our credentials, I tried username: admin and password: password just to check how it would behave. There was nothing special about that. So I viewed the page source (Ctrl+U as hinted), then there was a comment with the guest user credentials.

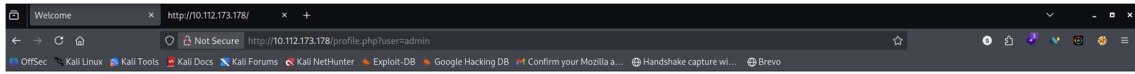


```
1
2 <!DOCTYPE html>
3 <html lang="en">
4 <head>
5   <meta charset="UTF-8">
6   <title>Login</title>
7   <link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.5.2/css/bootstrap.min.css">
8   <style>
9     body{ font: 14px sans-serif; }
10    .wrapper{ width: 360px; padding: 20px; margin: 0 auto; }
11  </style>
12 </head>
13 <body>
14   <div class="wrapper">
15     <h2>Login</h2>
16     <p>Please fill in your credentials to login.</p>
17
18     <form action="/index.php" method="post">
19       <div class="form-group">
20         <label>Username</label>
21         <input type="text" name="username" class="form-control" value="">
22         <span class="invalid-feedback"></span>
23       </div>
24       <div class="form-group">
25         <label>Password</label>
26         <input type="password" name="password" class="form-control">
27         <span class="invalid-feedback"></span>
28       </div>
29       <div class="form-group">
30         <input type="submit" class="btn btn-primary" value="Login">
31       </div>
32       <p>Don't have an account? Use the guest account! (<code>Ctrl+U</code>)</p>
33       <!-- use guest:guest credentials until registration is fixed. "admin" user account is off limits!!!! -->
34     </form>
35   </div>
36 </body>
37 </html>
```

I used those credentials and logged in.



Once logged in, I realized that the URL had a parameter whose value I could edit and attempt to perform IDOR. The first instinct was to replace “guest” with “admin”.



Hi, **admin**. Welcome to your site. The flag is: flag{

[Sign Out of Your Account](#)